

eVDP

Comprendre chaque étape du triage, en détail

Pourquoi chaque statut existe, qui est réellement informé, ce qui se déclenche automatiquement, et comment décider -- toutes les nuances vérifiées dans le code

Projet CYBER-DEF 2 -- Plateforme nationale de divulgation coordonnée de vulnérabilités
Dépot : github.com/wendiouedraogo8-art/evdp -- source : `apps/coordination/services.py`

Pourquoi ce document

Les tableaux de référence (eVDP_Guide_CSIRT_Triage.docx) donnent la liste des statuts et des transitions autorisées. Ce document va plus loin : il explique le RAISONNEMENT derrière chaque étape dès le tout début du parcours -- pourquoi elle existe, QUI agit et OU précisément dans l'interface, qui est réellement informé (avec des nuances précises vérifiées dans le code, parfois contre-intuitives), ce qui se déclenche automatiquement, et sur quels critères concrets une décision se prend. Chaque section reprend une question réellement posée et sa réponse vérifiée, corrigée là où une première explication était imprécise.

Comment une notification est livrée — la règle unique, valable partout

Avant de détailler statut par statut, une règle générale vérifiée dans le code (`apps/notifications/services.py`, fonction `notify()`) et qui s'applique IDENTIQUEMENT à chaque notification citée dans ce document, sans exception -- pour éviter de la répéter à chaque section :

- Une entrée apparaît TOUJOURS dans l'espace « Notifications » du destinataire dès lors qu'il possède un compte actif -- c'est le mécanisme de base, systématique.
- Un EMAIL est envoyé EN PLUS, en parallèle, uniquement si une adresse email est connue pour ce destinataire (compte avec email vérifié, ou contact laissé par un déclarant sans compte). Les deux (entrée interne + email) partent ensemble, dans la même action -- jamais l'un sans l'autre quand une adresse existe.
- Sans compte ET sans email connu (déclarant totalement anonyme, sans contact laissé) : aucune des deux formes n'est possible. La seule façon de suivre le dossier est de revenir consulter la page de suivi personnelle.

Remarque : Cette règle est GÉNÉRALE : quand une section plus bas dit simplement « notification spécifique » ou « notification générique », ça sous-entend toujours ce même mécanisme double (interne + email) -- sauf mention contraire explicite. Les rares exceptions (comme l'email direct à un déclarant sans compte mais avec un contact laissé, ou l'absence totale de tout envoi pour un anonyme sans contact) sont précisées à chaque fois qu'elles s'appliquent.

Le concept de SLA sur eVDP

Avant de détailler les effets SLA statut par statut, voici ce que ce mot recouvre concrètement sur la plateforme -- ce n'est pas juste un mot technique, c'est un engagement de délai mesuré automatiquement.

Un SLA (Service Level Agreement, engagement de délai) est une échéance chronométrée, attachée à un dossier, qui répond à une question précise : « est-ce que l'équipe respecte ses propres délais ? ». Il en existe CINQ TYPES indépendants, chacun mesurant une chose différente :

- Accuse de réception -- délai avant le premier accusé de réception au déclarant
- Premier triage -- délai avant la première qualification
- Réponse de l'organisation -- délai laissé à l'organisation affectée pour réagir après contact
- Remédiation -- délai de correction, dont la durée dépend de la sévérité
- Divulgaration -- délai avant publication, selon la politique nationale (90 jours par défaut)

Chaque échéance, à un instant donné, se trouve dans un des CINQ ETATS suivants :

- En cours -- le compte à rebours tourne, rien d'anormal
- Échéance proche -- le délai arrive bientôt à expiration
- Respecté -- l'action attendue a eu lieu à temps
- Dépasse -- le délai a expiré sans que l'action attendue n'ait eu lieu -- remonte automatiquement dans « Dossiers en retard » du tableau de bord CSIRT
- Annulé -- l'échéance ne s'applique plus (ex. dossier clôturé avant l'expiration)

Concrètement, une échéance SLA est créée (« démarrée ») par une transition de statut précise, et clôturée (« satisfaite ») par une autre -- les tableaux plus bas dans ce document indiquent exactement quel statut démarre ou clôture chaque échéance.

Remarque : Ces cinq échéances tournent INDEPENDAMMENT les unes des autres sur un même dossier -- un dossier peut avoir son SLA « Accusé de réception » déjà Respecté tout en ayant son SLA « Remédiation » en cours, par exemple.

Soumis — le point de départ automatique

Des qu'une personne (anonyme ou chercheur) envoie le formulaire, le dossier est créé avec le statut « Soumis » -- par défaut dans le modèle de données (CaseStatus.SUBMITTED), avant qu'aucun humain du CSIRT n'ait rien fait. C'est un état purement technique, pas une action de l'équipe.

Qui voit quoi : personne d'extérieur n'est notifiée à cet instant (pas de transition de statut déclenchée, donc pas d'email) -- seul le dossier existe désormais en base, visible par toute l'équipe CSIRT dès sa création. Après quoi : le dossier attend d'être remarqué -- direction « Reçu » ou directement « En triage » selon les deux seules transitions autorisées depuis cet état.

Reçu — pourquoi ça existe si personne n'est prévenu

Qui : n'importe quel rôle CSIRT (Coordinateur, Analyste, Agent de triage). Où : sur la fiche du dossier, carte « Changer le statut » -> choisir « Reçu » -> Appliquer -- rien d'autre à remplir.

« Reçu » ne dit rien au déclarant. Alors pourquoi cette étape existe-t-elle ? Deux raisons concrètes, vérifiées dans le code :

- Visibilité de charge de travail pour l'équipe -- sans ce marqueur, impossible de distinguer un dossier que personne n'a encore remarqué d'un dossier qu'un collègue a déjà repéré. Évitez un double traitement ou, pire, qu'un dossier reste silencieusement ignoré.
- Suivi de performance de l'équipe -- passer à « Reçu » suffit À LUI SEUL à satisfaire l'échéance SLA interne « Accusé de réception » (le compte à rebours qui mesure si l'équipe réagit à temps), MEME si le déclarant, lui, n'a encore rien reçu. C'est un indicateur de performance interne, pas une communication externe.

À retenir : « Reçu » ne parle à personne à l'extérieur -- c'est l'équipe CSIRT qui se parle à elle-même, pour rester organisée et mesurable.

Après quoi : deux destinations possibles ensuite -- « Accusé de réception » (le chemin normal, on informe le déclarant) ou directement « En triage » (si l'équipe préfère qualifier avant de contacter le déclarant -- les deux ordres sont légaux dans la table des transitions).

Accusé de réception — le vrai premier contact

Qui : n'importe quel rôle CSIRT (Coordinateur, Analyste, Agent de triage) -- mêmes rôles que pour « Reçu », aucune capacité supplémentaire requise au-delà de `CHANGE_CASE_STATUS`.

Ici, le CSIRT parle réellement au déclarant pour la première fois. C'est un engagement professionnel classique de toute politique de divulgation coordonnée.

Ce qu'il faut faire concrètement

Rien de plus qu'un clic : choisir le statut dans le menu déroulant, cliquer Appliquer. Le formulaire ne contient que le statut cible et un commentaire FACULTATIF.

Correction / attention : Le commentaire facultatif ne sert à rien pour le déclarant : il reste stocké uniquement dans l'historique interne (`CaseStatusHistory`), jamais inclus dans l'email automatique envoyé. L'email lui-même est un modèle fixe et standardisé (`NotificationKind.ACKNOWLEDGEMENT`) -- l'analyste ne rédige rien de personnalisé à cette étape.

Qui reçoit quoi

- S'il a un compte -> notification spécifique + email
- S'il n'a pas de compte mais a laissé un contact -> email direct à cette adresse
- S'il est totalement anonyme, sans email -> personne ne reçoit rien ; il devra revenir consulter sa page de suivi lui-même
- Le reste de l'équipe CSIRT est notifiée en même temps (sauf l'auteur de l'action)

À retenir : Cet événement peut un jour apparaître dans la chronologie PUBLIQUE d'un advisory publié -- contrairement à « Reçu » et « En triage », qui restent confidentiels pour toujours.

Après quoi : une seule destination possible ensuite -- « En triage ». Rien d'autre n'est autorisé depuis « Accusé de réception » dans la table des transitions.

En triage — le vrai travail commence

Qui : role CSIRT, generalement l'Analyste assigne. Où pour la transition elle-meme : toujours la carte « Changer le statut » -> « En triage » -> Appliquer. La lecture et l'analyse qui suivent se font en parcourant les autres cartes de la meme fiche (detail ci-dessous), pas ailleurs.

Premiere etape ou quelqu'un analyse reellement le contenu, au lieu de simplement faire avancer une file d'attente.

Comment l'analyste lit le signalement

Sur la fiche du dossier, la carte « Rapport » affiche, dans l'ordre : Description, Etapes de reproduction, Impact, Preuve de concept -- tout ce que le declarant a rempli. Des pastilles rapides montrent le score CVSS et le code CWE si renseignes. Si le contenu est chiffre en PGP, il apparait aussi ici, mais reste illisible tant qu'il n'est pas dechiffre hors ligne.

Qu'est-ce qu'une Preuve de concept, precisement

A ne pas confondre avec la Description (explique le probleme en mots) ni les Etapes de reproduction (la marche a suivre) : la Preuve de concept est l'ARTEFACT CONCRET qui prouve que la faille fonctionne reellement -- pas une affirmation theorique.

Elle peut prendre plusieurs formes : une requete HTTP exacte et son resultat, un payload d'exploitation, un extrait de code, une sequence de commandes. En piece jointe (formats explicitement acceptes par la plateforme) : capture d'ecran (png/jpg/gif/webp/heic), trace reseau (.har, .pcap), journal (.log), donnees structurees (.json/.csv/.xml), email complet (.eml), archive (.zip), rapport (.pdf).

C'est le declarant lui-meme qui la fournit, dans la section « Details techniques (optionnel) » du formulaire de signalement -- jamais le CSIRT.

Remarque : C'est aussi le contenu le plus souvent candidat au champ chiffre PGP : un PoC fonctionnel qui fuiterait avant correction donnerait directement les moyens d'exploiter la faille.

Comment il tente de reproduire

- Recupere l'URL/endpoint et le produit vises
- Suit les etapes de reproduction dans un environnement de test, jamais directement sur le systeme cible sans autorisation
- Consulte les pieces jointes pour confirmer visuellement
- Dechiffre d'abord le contenu PGP si necessaire
- Compare avec la preuve de concept pour valider la correspondance

Le premier vrai point de décision

Jusqu'ici, chaque etape n'avait qu'une seule suite logique. « En triage » est le premier embranchement reel -- sept destinations possibles, detaillees ci-dessous, AVEC l'emplacement exact dans l'interface pour chacune (elles ne passent pas toutes par le meme mecanisme).

Issue depuis « En triage »	Critère de décision concret	Où, dans l'interface
----------------------------	-----------------------------	----------------------

Informations demandées	La reproduction échoue par manque de détail -- on redemande plutôt que de trancher à l'aveugle.	Carte « Changer le statut » -> choisir la valeur -> Appliquer. PUIS, séparément, carte « Publier un message » (niveau « Participants ») pour préciser quoi -- sinon le déclarant ne sait pas quoi fournir.
Validé	La faille a été reproduite ou la preuve de concept est suffisamment convaincante pour confirmer qu'elle est réelle et exploitable	Carte « Changer le statut » -> « Validé » -> Appliquer
Doublon	Un autre dossier déjà ouvert décrit exactement la même faille -- comparer via le menu « Dossiers » et sa recherche	PAS via « Changer le statut » : carte DÉDIÉE « Marquer comme doublon », qui demande la référence du dossier original (ex. EVDP-2026-000001) -- voir détail ci-dessous
Rejeté	Après analyse et tentative de reproduction, ce n'est pas une vraie vulnérabilité, ou la preuve ne tient pas	Carte « Changer le statut » -> « Rejeté » -> Appliquer
Hors périmètre	La cible touchée n'est pas couverte par le programme visé (ex. domaine explicitement exclu dans les règles)	Carte « Changer le statut » -> « Hors périmètre » -> Appliquer
Non applicable	Le comportement signalé existe bien mais n'est en réalité pas un problème de sécurité	Carte « Changer le statut » -> « Non applicable » -> Appliquer
Informatif	Un constat valide, mais qui ne nécessite pas de correction (ex. simple recommandation d'amélioration)	Carte « Changer le statut » -> « Informatif » -> Appliquer

Remarque : Sortir de « En triage » (vers n'importe laquelle de ces sept destinations) exige la capacité TRIAGE_CASE -- y entrer, en revanche, ne demande rien de spécial. Un rôle sans cette capacité pourrait faire passer un dossier « En triage » mais resterait bloqué pour le faire avancer davantage.

Le cas particulier de « Doublon », en détail

Contrairement aux six autres issues, « Doublon » n'est PAS un simple choix dans le menu déroulant « Changer le statut ». J'ai vérifié le code (`apps/coordination/views.py`, `apps/coordination/services.py`) : c'est une action DEDIEE, avec sa propre carte sur la fiche du dossier (« Marquer comme doublon »), parce qu'elle a besoin d'une information que la transition générique ne demande pas -- LEQUEL est le dossier original.

- Le formulaire dédié demande la référence exacte du dossier original (ex. EVDP-2026-000001)
- En validant, DEUX choses se produisent en une seule action : le champ `duplicate_of` du dossier est rempli (lien technique vers l'original), ET le statut bascule à « Doublon » -- pas besoin de faire les deux séparément
- Vérifications automatiques : impossible de marquer un dossier comme doublon de lui-même, et impossible de créer une référence circulaire (A doublon de B, B doublon de A)

Correction / attention : Point de confidentialité important, écrit explicitement en commentaire dans le code : « Le déclarant est informé du doublon mais n'obtient AUCUNE information sur le cas original (identifiant, organisation, contenu) ». Le chercheur du dossier B ne saura jamais que son signalement recoupe le dossier X d'un autre chercheur -- seul le CSIRT voit le lien entre les deux.

Ce qui suit ces cinq issues : qui est notifié, et surtout ce qui vient après

Les quatre autres issues (Rejete, Hors perimetre, Non applicable, Informatif) n'ont pas de section dediee comme les etapes du chemin principal, mais meritent la meme rigueur sur ces deux points -- avec une decouverte precise, verifiee dans apps/coordination/workflow.py, qui n'etait pas documentee jusqu'ici.

Issue	Qui est notifié	Ce qui vient après
Doublon	Déclarant : notification SPÉCIFIQUE (sans detail sur l'original) + équipe : générique	CUL-DE-SAC DÉFINITIF
Rejeté	Déclarant : notification SPÉCIFIQUE + équipe : générique	CUL-DE-SAC DÉFINITIF
Hors périmètre	Équipe : générique seulement (rien de spécifique au déclarant)	CUL-DE-SAC DÉFINITIF
Non applicable	Équipe : générique seulement	CUL-DE-SAC DÉFINITIF
Informatif	Équipe : générique seulement	Seule exception : peut encore aller vers « Clos »

Correction / attention : Verification precise du code (les tables VDP_TRANSITIONS et BOUNTY_TRANSITIONS de apps/coordination/workflow.py) : Doublon, Rejete, Hors perimetre et Non applicable ne figurent PAS comme cles dans ces tables de transitions -- ce qui signifie qu'AUCUNE transition sortante n'existe depuis ces quatre statuts, y compris vers « Clos ». Une fois qu'un dossier y arrive, il y reste pour toujours ; ce ne sont pas des etapes vers une cloture ulterieure, ce SONT deja la fin du parcours. Seul « Informatif » fait exception parmi les issues d'abandon : une transition explicite vers « Clos » existe pour lui. Intuitivement, on pourrait croire que tout finit par passer par « Clos » -- ce n'est vrai que pour Informatif et pour les dossiers qui suivent le chemin complet (Correctif verifie, Divulgarion planifiee, Publie).

Informations demandées — un cas à deux temps

Le formulaire de changement de statut ne contient toujours que le statut cible et un commentaire FACULTATIF -- et ce commentaire n'est, encore une fois, JAMAIS envoyé au déclarant. La notification automatique dit juste « des informations sont nécessaires », sans préciser lesquelles.

Correction / attention : Pour que ce soit utile, l'analyste doit poster un VRAI message séparé (carte « Publier un message », niveau « Participants du cas ») expliquant concrètement ce qui manque. Deux actions distinctes, pas une seule.

Une vraie différence anonyme / chercheur inscrit

Poster ou répondre à un message exige d'être connecté (@login_required vérifié dans le code).

- Chercheur inscrit -> peut se connecter, voir le message, et répondre lui-même (uniquement au niveau « Participants du cas », jamais « Interne CSIRT »)
- Déclarant anonyme -> reçoit l'email générique si un contact a été laissé, mais NE PEUT PAS répondre sur la plateforme -- pas de compte, pas de connexion, pas de messagerie accessible. Il devrait répondre par un autre canal (email direct, hors eVDP).

Ensuite : retour à « En triage » une fois la réponse obtenue, ou directement vers une issue de triage si la réponse ne vient jamais.

Validé — la bascule vers l'action

« Valide » certifie que la faille est réelle. C'est la bascule entre « on regarde » et « on agit ».

Correction / attention : Correction par rapport à une explication précédente : l'échéance SLA « Remediation » ne démarre PAS à l'étape « Remediation en cours » plus loin dans le parcours -- elle démarre déjà ICI, dès « Valide ». « Remediation en cours » ne fait que confirmer que le travail a concrètement commencé, le compte à rebours tourne déjà depuis un moment.

Quatre effets automatiques vérifiés dans le code (apps/coordination/services.py) :

- Horodatage validated_at (première fois seulement)
- Calcul automatique de la date de divulgation (aujourd'hui + délai du programme, ex. 90 jours)
- Démarrage de l'échéance SLA Remediation -- durée DIRECTEMENT dépendante de la sévérité qualifiée plus tôt : une sévérité mal renseignée fausse ce délai
- Attribution d'un point de réputation au chercheur -- SEULEMENT s'il a un compte ; jamais pour un déclarant anonyme, faute de profil pour le recevoir

Qui reçoit quoi : le déclarant reçoit une notification SPÉCIFIQUE (contenu dédié « Signalement validé »), en plus du point de réputation s'il a un compte ; l'équipe reçoit la notification générique habituelle.

Capacité requise : TRIAGE_CASE (mêmes rôles que pour sortir de « En triage »). Trois destinations possibles ensuite : En cours de traitement, Organisation contactée, ou retour à Informations demandées/Doublon si un doute subsiste encore.

Organisation contactée — le moment où l'accès s'ouvre réellement

C'est le moment où le CSIRT engage FORMELLEMENT l'organisation affectée -- officiellement, « on leur en parle ».

Correction / attention : Correction de securite appliquee suite a une verification approfondie : a l'origine, une organisation pouvait voir un dossier qui la concernait DES SA CREATION, quel que soit son statut -- y compris un signalement encore non trie, potentiellement faux, avant toute validation du CSIRT. Ca contredisait directement la raison d'etre d'un CSIRT coordinateur, et le probleme meme que le cahier des charges du projet identifie (« aucun canal officiel... risque de poursuites » pour le declarant). C'est desormais corrige : l'organisation n'a accès au dossier qu'A PARTIR de cette transition precise -- jamais avant.

Trois effets, verifiés dans le code, se produisent en meme temps :

- Demarre l'echeance SLA « Reponse de l'organisation »
- Evenement ajoute a la chronologie -- publiable dans un futur advisory
- RATTACHE les contacts de l'organisation (Responsable/DSI/Contact securite) comme participants du dossier -- c'est cette action precise qui leur ouvre l'accès, pas une regle automatique liee a leur organisation

Remarque : Meme piege que pour « Informations demandees » : la notification qui part a ce moment est generique (« Statut modifie »), sans contenu precis. Si le CSIRT veut que l'organisation comprenne concretement ce qu'on attend d'elle, un message separe (carte « Publier un message », niveau « Participants du case ») reste necessaire.

Capacite requise : aucune au-dela de CHANGE_CASE_STATUS. Carte « Changer le statut » -> « Organisation contactee » -> Appliquer.

Le déroulé technique complet, du clic à l'email

Trace precise dans le code, etape par etape :

- 1. Le clic sur « Appliquer » envoie une requete vers la vue change_status, avec le statut cible choisi
- 2. Verification : la transition est-elle legale depuis l'etat actuel (tableau des transitions) ET le compte a-t-il la capacite requise ? Si refuse, rien ne se passe, juste une trace « refuse » dans le journal d'audit
- 3. Si autorise, tout ce qui suit se produit en UNE SEULE transaction atomique : mise a jour du statut en base ; rattachement des contacts de l'organisation comme participants (le correctif qu'on vient de faire) ; enregistrement de l'historique interne ; ajout d'un evenement a la chronologie ; programmation de l'echeance SLA « Reponse de l'organisation » ; entree dans le journal d'audit global
- 4. Notification : tous les participants actifs du dossier sont notifies -- et l'organisation, venant tout juste d'etre ajoutée a l'etape 3, est incluse DANS CETTE MEME ACTION

Remarque : Contenu exact de l'email envoye (« Organisation contactee » n'a pas de modele dedie, donc utilise le message generique) : Objet « [eVDP] Mise a jour du dossier EVDP-2026-XXXXXX » -- Corps « Le statut du dossier EVDP-2026-XXXXXX a evolue. Consultez le detail dans votre espace securise : [lien] ». Rien de plus precis -- meme piege que « Informations demandees ».

Techniquement, l'envoi se fait de facon SYNCHRONE (Django appelle directement send_mail, pas de file d'attente en arriere-plan), dans la meme requete que le changement de statut. Si l'envoi echoue (SMTP indisponible...), l'erreur est capturee et journalée discretement -- le changement de statut reste applique meme si l'email echoue.

Organisation a accusé réception — le miroir, côté organisation

A ne pas confondre avec l'etape precedente : « Organisation contactee » = l'ENVOI (le CSIRT notifie l'organisation, comme poster une lettre). « Organisation a accuse reception » = la REPONSE (l'organisation confirme avoir recu, comme un accuse de reception postal). Toujours dans cet ordre -- jamais l'inverse, la table des transitions ne le permet meme pas techniquement.

C'est exactement le meme principe que « Accuse de reception » tout au debut du parcours, applique a un autre maillon de la chaine : chercheur -> CSIRT au debut, puis CSIRT -> organisation ici.

Pas de bouton dédié — le même mécanisme générique que partout ailleurs

Verifie precisement dans le code de la vue case_detail : la carte « Changer le statut » s'affiche pour TOUT compte ayant la capacite CHANGE_CASE_STATUS -- et un Responsable d'organisation/DSI l'a bien.

Ce que le DSI voit concretement, une fois connecte sur la fiche du dossier (accessible depuis « Organisation contactee », grace au correctif de securite) :

- La meme carte « Changer le statut »
- Un menu deroulant, qui ne propose QUE les transitions legales depuis l'etat actuel -- puisque le dossier est a « Organisation contactee », les deux seules options sont « Organisation a accuse reception » et « Remediation en cours » (les autres statuts n'apparaissent meme pas dans la liste)
- Un bouton « Appliquer »

Concretement, ce qu'il fait :

- 1. Ouvre le dossier
- 2. Carte « Changer le statut » -> selectionne « Organisation a accuse reception » dans le menu deroulant (une des deux seules options disponibles a ce stade)
- 3. Clique « Appliquer »

Qui clique concretement, en pratique : soit l'organisation elle-meme (le DSI, comme ci-dessus), soit le CSIRT a sa place si la reponse est arrivee par un autre canal (email classique, telephone) plutot que directement sur la plateforme.

Effet automatique : cloture l'echeance SLA « Reponse de l'organisation » demarree a l'etape precedente. Contrairement a « Organisation contactee », cet evenement N'EST PAS publiable dans un futur advisory -- un advisory pourra dire « l'organisation a ete contactee le X », jamais « elle a repondu le Y ».

Destination unique ensuite : « Remediation en cours » -- pas de bifurcation, le parcours redevient lineaire.

Remédiation en cours — le déclencheur est toujours hors plateforme

Le travail de correction a concretement commence, cote organisation (ou en interne si le systeme touche appartient directement a l'ANSSI-BF).

Qu'est-ce qui declenche concretement ce clic ?

Comme pour TOUTES les transitions de ce workflow, rien dans eVDP ne detecte automatiquement qu'une correction a demarre -- aucune integration avec les systemes internes de developpement de l'organisation n'existe. Le declencheur reel est toujours hors plateforme : un appel telephonique, un

email classique, un message poste sur le dossier par l'organisation elle-meme (« nous avons commence a corriger »), ou une confirmation verbale. Le clic sur le bouton est un acte humain qui vient ENREGISTRER une realite deja constatee ailleurs -- jamais l'inverse.

D'où on peut arriver ici — un point de convergence

Contrairement a la plupart des etapes precedentes (un seul chemin logique), « Remediation en cours » est accessible depuis TROIS statuts differents :

- « Organisation a accuse reception » -- le chemin complet et normal
- « Organisation contactee » directement -- si le CSIRT constate par un autre moyen que la correction a commence, sans attendre l'accuse de reception formel
- « En cours de traitement » directement -- le cas ou il n'y a pas d'organisation externe a contacter du tout

Correction / attention : Correction par rapport a une explication precedente dans cette meme conversation : le SLA « Remediation » n'est pas simplement « deja en cours depuis Valide, rien de nouveau ici ». En verifiant la fonction technique `schedule_sla()` : si l'echeance programme a « Valide » est TOUJOURS EN COURS (pas encore depassee) au moment ou le dossier atteint « Remediation en cours », cette meme fonction est appelee -- et comme l'echeance existe deja et est toujours active, SA DATE LIMITE EST RECALCULEE ET REMPLACEE, a partir de ce nouvel instant, pas de la date de Valide. Concretement : si plusieurs jours se sont ecoules entre Valide et le vrai debut de la remediation, le delai est repousse d'autant. Ce n'est pas forcément un bug -- ca peut refleter un choix assume (delai recalcule sur la base la plus recente) -- mais ca vaut la peine d'etre su avant de presenter ce mecanisme comme parfaitement previsible.

Ce qui suit — un détail de pratique CVD réelle

Deux destinations : « Correctif disponible » (le chemin normal), ou directement « Divulgence planifiee » -
- un raccourci qui existe precisement pour le cas ou le delai s'ecoule sans correctif. La pratique standard de divulgation coordonnee autorise a publier meme sans correctif, pour mettre la pression et informer le public, plutot que d'attendre indefiniment.

Capacite requise : aucune au-dela de `CHANGE_CASE_STATUS`. Aucun effet de notification specifique (statut absent de `STATUS_NOTIFICATIONS`) -- seule la notification generique « Statut modifie » part vers les participants.

Correctif disponible — une déclaration, pas encore une preuve

Qui : role CSIRT (ou l'organisation elle-meme, si son compte a la capacite `CHANGE_CASE_STATUS`). Ou : carte « Changer le statut » -> « Correctif disponible » -> Appliquer -- un seul clic, comme la plupart des transitions de ce parcours.

« Un correctif existe / a ete produit » -- la question posee dans cette meme conversation -- signifie precisement ceci : l'organisation AFFIRME qu'une correction a ete developpee et est prete (ou deja deployee), pas que le CSIRT l'a lui-meme constate ou verifie. C'est une declaration, enregistree comme un fait a ce stade -- la verification independante est volontairement une etape SEPAREE, juste apres.

Un chemin qui n'est pas toujours obligatoire

En verifiant precisement les deux tables de transitions du code (`apps/coordination/workflow.py`), une asymetrie reelle apparait entre les deux workflows de la plateforme :

- Volet VDP (signalement citoyen classique) -- depuis « Remediation en cours », la SEULE suite possible vers la verification est « Correctif disponible » : ce statut est OBLIGATOIRE, impossible de le sauter.
- Volet Bug Bounty -- depuis « Remediation en cours », DEUX suites sont possibles : soit « Correctif disponible » (chemin complet), soit directement « Verification du correctif », en sautant cette etape.

Correction / attention : Cette difference n'est pas un oubli : elle reflète un choix assume. Le volet VDP, plus formel et institutionnel, impose de tracer explicitement la declaration de disponibilite avant toute verification. Le volet Bug Bounty, plus operationnel, autorise un chemin raccourci quand l'organisation et le CSIRT constatent la correction et sa verification en meme temps (ex. via une seule communication).

Qui reçoit quoi : aucune notification spécifique au déclarant (statut absent de `STATUS_NOTIFICATIONS`) -- seule l'équipe reçoit la notification générique. Le déclarant ne sait donc pas, par une notification dédiée, qu'un correctif est annoncé -- seul un message manuel séparé le lui dirait.

Effet automatique : satisfait l'echeance SLA « Remediation » (le delai de correction est considere respecte a cet instant) ; horodatage `remediated_at` fixe si c'est la premiere fois. Destination unique ensuite : « Verification du correctif ».

Vérification du correctif — le CSIRT constate, indépendamment

Qui : role CSIRT (Analyste ou Coordinateur), jamais l'organisation elle-meme -- ce serait juge et partie. Ou : carte « Changer le statut » -> « Verification du correctif » -> Appliquer.

C'est le pendant, cote correction, de ce qu'etait « En triage » cote signalement initial : la premiere fois qu'un correctif declare est reellement EXAMINE par quelqu'un d'independant de l'organisation, plutot que simplement enregistre sur sa parole. En pratique CVD standard, ca consiste a retester le scenario de reproduction d'origine contre l'environnement corrige (ou une preuve fournie par l'organisation -- capture, journal, nouvelle version deployee) pour confirmer que la faille ne se declenche plus.

Remarque : Statut intermediaire manuel, sans aucun effet technique automatique propre -- aucune echeance SLA n'y demarre ni ne se cloture specifiquement a cette etape ; le SLA Remediation reste deja satisfait depuis « Correctif disponible ».

Deux issues, symétriques à « En triage »

- « Correctif vérifié » -- la correction tient réellement, confirmée
- Retour à « Remédiation en cours » -- le correctif ne résout pas (ou résout mal) le problème d'origine ; l'organisation doit reprendre le travail. Boucle explicitement prévue dans le code, pas une impasse.

Qui reçoit quoi : comme pour « Correctif disponible », aucune notification spécifique -- ni pour confirmer l'examen en cours, ni pour un éventuel retour à « Remédiation en cours ». Seule la notification générique part vers l'équipe (et l'organisation, déjà participante à ce stade).

Correctif vérifié — la confirmation qui compte

La correction a été indépendamment confirmée efficace par le CSIRT. C'est la dernière étape purement technique du parcours -- tout ce qui suit concerne la communication, plus la remédiation elle-même.

Qui reçoit quoi : aucune notification spécifique au déclarant ici non plus -- il n'apprend pas, par un message dédié, que le correctif est confirmé efficace. Seule la notification générique part vers l'équipe. La communication réelle vers le public passera plus loin par l'advisory (voir « Publié »).

Effet automatique : satisfait de nouveau l'échéance SLA « Remédiation » -- sans conséquence visible si elle était déjà satisfaite depuis « Correctif disponible » (cas normal), utile seulement si le chemin raccourci Bug Bounty a sauté cette étape intermédiaire. Horodatage `remediated_at` fixe si ce n'était pas déjà le cas.

Capacité requise : aucune au-delà de `CHANGE_CASE_STATUS`. Deux destinations : « Divulgence planifiée » (chemin normal), ou directement « Clos » -- pour les cas où aucune communication publique n'est prévue (ex. correction mineure, pas de CVE, programme qui ne publie pas systématiquement d'advisory).

Divulgence planifiée — un statut, pas encore une échéance surveillée

Qui : rôle CSIRT avec CHANGE_CASE_STATUS. Ou : carte « Changer le statut » -> « Divulgence planifiée » -> Appliquer.

Ce statut confirme qu'une date de communication publique est retenue -- l'organisation a eu le délai convenu, le correctif est vérifié, on communique désormais sur un calendrier.

Correction / attention : Point vérifié précisément dans le code (apps/coordination/services.py), et plus subtil qu'il n'y paraît : CE statut, à lui seul, NE DEMARRE AUCUNE échéance SLA. Trois choses distinctes existent, faciles à confondre : (1) le champ disclosure_date, calcule AUTOMATIQUEMENT des « Valide » (aujourd'hui + délai du programme) ; (2) ce statut « Divulgence planifiée », un simple changement via la carte générique, qui à lui seul ne modifie rien d'autre ; (3) l'échéance SLA « Divulgence » réellement SURVEILLÉE (celle qui peut apparaître « Dépassée » au tableau de bord), qui n'est créée QUE par l'action séparée « Planifier ou ajuster la date de divulgation » (fonction schedule_disclosure), documentée plus haut dans les deux actions annexes. Conséquence concrète : un dossier peut afficher le statut « Divulgence planifiée » sans qu'aucune échéance active ne surveille réellement sa date -- si l'équipe se contente de changer le statut sans jamais utiliser la carte dédiée, un dépassement de date ne remontera jamais automatiquement dans « Dossiers en retard ».

Qui reçoit quoi : aucune notification spécifique au déclarant -- seule la notification générique part vers l'équipe et l'organisation. Le déclarant n'apprend donc pas, par ce statut seul, qu'une date de publication est envisagée.

Effet réellement automatique du seul changement de statut : un événement de chronologie est ajouté -- mais ce type d'événement (contrairement à « Organisation contactée », « Valide », etc.) ne fait PAS partie de la liste des événements publiables dans un futur advisory.

Destination ensuite : « Publie » (le chemin normal), ou directement « Clos » -- abandon de la publication, décision qui reste possible à tout moment jusque-là.

Publié — deux actions distinctes, trop facilement confondues

C'est ici que la nuance la plus importante de tout ce parcours apparaît. Le statut « Publie » du DOSSIER et la publication réelle d'un advisory PUBLIC sont deux choses portées par deux objets différents du système -- pas la même action, même si le nom prétend le contraire.

Ce que le seul changement de statut du dossier déclenche

Via la carte générique « Changer le statut » -> « Publie » -> Appliquer : le dossier est marqué is_published=True (un simple indicateur interne) ; toutes les échéances SLA encore en attente sont annulées ; un événement de chronologie est ajouté. Rien de plus -- en particulier, AUCUN contenu public n'est créé par cette seule action, aucun texte n'est rédigé, aucun email n'est envoyé à qui que ce soit.

La vraie publication : un objet Advisory séparé, avec son propre parcours

Publier réellement un advisory passe par un module distinct (apps/disclosures), avec un workflow en deux temps bien séparés :

- 1. Rédaction -- un analyste crée un brouillon d'advisory à partir du dossier. Seuls des champs non sensibles sont recopiés automatiquement (titre, produit, sévérité, CVE/CWE, score CVSS, crédit du chercheur, chronologie publique) -- JAMAIS la preuve de concept, les étapes de reproduction,

l'URL cible ou les pieces jointes. Le resume public, lui, doit etre redige a la main par l'analyste -- impossible de publier sans.

- 2. Publication -- une action separee, qui rend l'advisory effectivement visible sur la page publique des advisories, le tableau de bord et les metriques.

Séparation des pouvoirs, à dessein

Verifie precisement dans les roles (apps/accounts/roles.py) : REDIGER un advisory et le PUBLIER n'exigent pas la meme capacite.

Rôle	Peut rédiger (DRAFT_ADVISORY)	Peut publier (PUBLISH_ADVISORY)
Analyste CSIRT	Oui	Non
Coordinateur national	Oui	Oui

Un analyste peut preparer un brouillon complet, mais seul le Coordinateur national (ou le Super-admin) peut declencher la publication finale. C'est un controle a deux personnes (principe des quatre yeux) -- pratique standard des plateformes CVD professionnelles, pour eviter qu'un texte public parte sans validation hierarchique.

Remarque : Correction apportee apres verification plus approfondie du code : la transition du STATUT du dossier vers « Publie » exige elle aussi, precisement, la capacite PUBLISH_ADVISORY (voir TRANSITION_CAPABILITIES) -- pas seulement CHANGE_CASE_STATUS comme la plupart des autres statuts. Un Analyste ou un Agent de triage, qui n'ont pas cette capacite, ne peuvent donc PAS faire passer un dossier au statut « Publie », meme sans advisory reel. Les deux actions restent neanmoins deux objets techniquement independants (Case vs Advisory) : rien n'empeche mecaniquement de changer le statut du dossier sans qu'un advisory correspondant existe reellement, si l'unique personne qui agit oublie l'un des deux gestes.

Ce qui se passe réellement à la publication de l'advisory

Quand le Coordinateur publie effectivement l'advisory (fonction publish_advisory) : l'advisory devient visible publiquement ; un evenement d'audit et un evenement de chronologie sont enregistres sur le dossier d'origine ; le DECLARANT reçoit une notification SPECIFIQUE et dediee (« Advisory publie ») -- distincte de la notification generique envoyee a chaque changement de statut ; l'action est ensuite consideree irreversible, sauf retrait explicite et motive (fonction retract_advisory, elle aussi separee, avec sa propre capacite et son propre motif obligatoire).

Destination finale : « Clos ».

Clos — la seule vraie fin du parcours

Qui : role CSIRT (ou organisation) avec CHANGE_CASE_STATUS, aucune capacite supplementaire requise - meme regle que la plupart des transitions simples. Ou : carte « Changer le statut » -> « Clos » -> Appliquer.

« Clos » est le seul statut du parcours complet qui soit reellement terminal ET atteignable depuis PLUSIEURS chemins differents -- il n'existe pas un seul « bon moment » pour cloturer, ca depend de ce qui a ete decide pour ce dossier precis :

- Depuis « Correctif verifie » -- la faille est corrige, confirmee, mais aucune communication publique n'est prevue (ex. correction mineure, pas de CVE, programme qui ne publie pas systematiquement)
- Depuis « Divulgateion planifiee » -- une date etait prevue, mais la publication est finalement abandonnee
- Depuis « Publie » -- le chemin complet et normal : advisory publie, dossier cloture juste apres
- Depuis « Informatif » -- le seul des cinq statuts d'abandon du triage qui puisse encore atteindre « Clos » (voir plus haut)

Effets automatiques, verifiees dans le code : horodatage `closed_at` enregistre (une seule fois, comme les autres horodatages du parcours) ; TOUTES les echeances SLA encore en attente sont annulees -- exactement le meme mecanisme que pour « Publie », ce qui est logique puisque « Publie » mene lui-meme systematiquement ici ; un evenement de chronologie est ajoute.

Remarque : « Clos » ne retire PAS le dossier de la liste des dossiers ni de sa fiche detaillee -- l'organisation continue d'y avoir acces (il fait partie des etats `ORG_VISIBLE_STATES`). La seule chose qui change concretement dans l'interface : il disparaît du tableau Kanban, qui exclut explicitement les dossiers Clos de ses colonnes (il resterait sinon indefiniment affiche comme « actif » alors que le travail est termine).

Aucune notification specifique au declarant n'est prevue pour ce statut (absent de `STATUS_NOTIFICATIONS`) -- seule la notification generique part vers les participants actifs du dossier.

Deux actions annexes, en dehors du fil principal des statuts

Deux actions supplementaires existent sur la fiche du dossier, independantes de la carte « Changer le statut » -- elles ne font PAS avancer le workflow, elles ajoutent une information complementaire.

Associer un CVE

Si le declarant avait coche « Je demande l'attribution d'un CVE » a la soumission, une carte dediee permet d'associer l'identifiant CVE obtenu (ex. CVE-2026-XXXXX) au dossier, une fois celui-ci attribue par l'autorite competente. Simple metadonnee -- aucun effet sur le statut, aucune notification declenchee. Capacite requise : `CHANGE_CASE_STATUS` (la meme que pour la plupart des transitions simples).

Planifier ou ajuster la date de divulgation

On a vu que « Valide » calcule AUTOMATIQUEMENT une date de divulgation (aujourd'hui + delai du programme). Une carte separee permet de la RE-planifier manuellement si necessaire -- ex. un correctif prend plus de temps que prevu, ou l'organisation demande un delai supplementaire. Ce n'est pas la meme action que passer au statut « Divulgateion planifiee » : celle-ci change le statut, celle-la ajuste seulement la date associee. Les deux sont independantes et peuvent se faire dans n'importe quel ordre.

Tableau récapitulatif — quel statut envoie un email, et à qui

Couvre les 24 statuts réellement atteignables (DRAFT exclu : jamais utilisé en pratique, un dossier est créé directement à Soumis). Deux mécanismes tournent en parallèle à CHAQUE transition, sans exception : une notification GÉNÉRIQUE « Statut modifié » vers tous les participants actifs du dossier (équipe CSIRT, organisation une fois rattachée, et le déclarant lui-même s'il est déjà participant) ; et, uniquement pour 5 statuts précis, une notification SPÉCIFIQUE en plus, avec un contenu dédié, adressée au déclarant.

Statut	Équipe / participants (dont l'organisation, une fois rattachée)	Déclarant
Soumis	— (création du dossier, pas une transition)	—
Reçu	Générique	Rien
Accusé de réception	Générique	SPÉCIFIQUE (email/contact) ou rien (anonyme sans contact)
En triage	Générique	Rien
Informations demandées	Générique	SPÉCIFIQUE (contenu générique -- message séparé requis pour préciser quoi) ou rien (anonyme sans contact)
Validé	Générique	SPÉCIFIQUE + 1 point de réputation si compte
Doublon	Générique	SPÉCIFIQUE -- mais sans aucune information sur le dossier original
Rejeté	Générique	SPÉCIFIQUE
Hors périmètre	Générique	Rien (statut absent de la liste des notifications spécifiques)
Non applicable	Générique	Rien
Informatif	Générique	Rien
Sévérité attribuée	Générique	Rien
Revue de récompense	Générique	Rien (mais visible dans son espace "Récompenses")
Récompense approuvée	Générique	Rien (idem)
En cours de traitement	Générique	Rien
Organisation contactée	Générique -- l'organisation est ATTACHÉE comme participant à cet instant précis, donc incluse dans cet envoi	Rien
Organisation a accusé réception	Générique	Rien
Remédiation en cours	Générique	Rien
Correctif disponible	Générique	Rien
Vérification du correctif	Générique	Rien

Correctif vérifié	Générique	Rien
Divulgateion planifiée	Générique	Rien
Publié	Générique	Rien (mais le contenu devient visible publiquement, sans notification individuelle)
Clos	Générique	Rien

Remarque : « Spécifique » ne veut pas dire « détail » : même les 5 notifications spécifiques (Accuse de réception, Informations demandées, Valide, Rejete, Doubleon) restent des modèles fixes et courts -- pour un contenu vraiment précis (ex. quelle information manque), un message séparé (carte « Publier un message ») reste toujours nécessaire.

Tableau récapitulatif — les effets techniques automatiques

Statut	Effet technique automatique déclenché
Reçu	Satisfait l'échéance SLA « Accusé de réception » (le compte à rebours interne s'arrête déjà ici, même si le déclarant n'a encore rien reçu)
Accusé de réception	Satisfait aussi cette même échéance SLA (redondant avec Reçu si déjà passé par là) ; événement ajouté à la chronologie PUBLIQUE potentielle (advisory futur)
En triage	Satisfait l'échéance SLA « Premier triage » ; événement de chronologie strictement INTERNE, jamais publiable
Validé	Calcule la date de divulgation (aujourd'hui + délai du programme) ; DÉMARRE l'échéance SLA « Remédiation » (dépend de la sévérité qualifiée) ; +1 réputation si compte ; événement publiable
Organisation contactée	Démarre l'échéance SLA « Réponse de l'organisation »
Organisation a accusé réception	Clôture cette même échéance SLA
Remédiation en cours	Aucun nouvel effet SLA -- le compte à rebours tourne déjà depuis « Validé »
Correctif disponible	Satisfait l'échéance SLA « Remédiation » (marque le délai de correction comme respecté) ; horodatage remediated_at enregistré si c'est la première fois que le dossier atteint Correctif disponible OU Correctif vérifié
Vérification du correctif	Aucun effet technique automatique -- statut intermédiaire manuel, aucune échéance SLA n'y est directement rattachée
Correctif vérifié	Satisfait à nouveau l'échéance SLA « Remédiation » (sans effet si déjà satisfaite à Correctif disponible, ce qui est le cas normal) ; horodatage remediated_at si pas déjà fixé plus tôt
Divulgateion planifiée	AUCUN effet technique lié au statut lui-même -- l'échéance SLA « Divulgation » n'est démarrée que par l'action séparée « Planifier ou ajuster la date de divulgation », indépendante de ce changement de statut (voir avertissement dédié)
Publié	Toutes les échéances SLA encore EN COURS sont annulées (le dossier est arrivé au bout de son cycle, plus rien à surveiller) ; is_published=True enregistré sur le dossier
Clos	Horodatage closed_at enregistré (première fois) ; toutes les échéances SLA encore en attente sont annulées (même mécanisme que Publié) ; disparaît des colonnes du tableau Kanban (reste visible partout ailleurs)

